UBAYA
UNIVERSITAS SURABAYA

1604C051 – Full-stack Programming

Security

Week 07

Program Studi Teknik Informatika
Fakultas Teknik – Universitas Surabaya

Hendra Dinata

Transmisi Data

Apa yang terjadi dengan data?



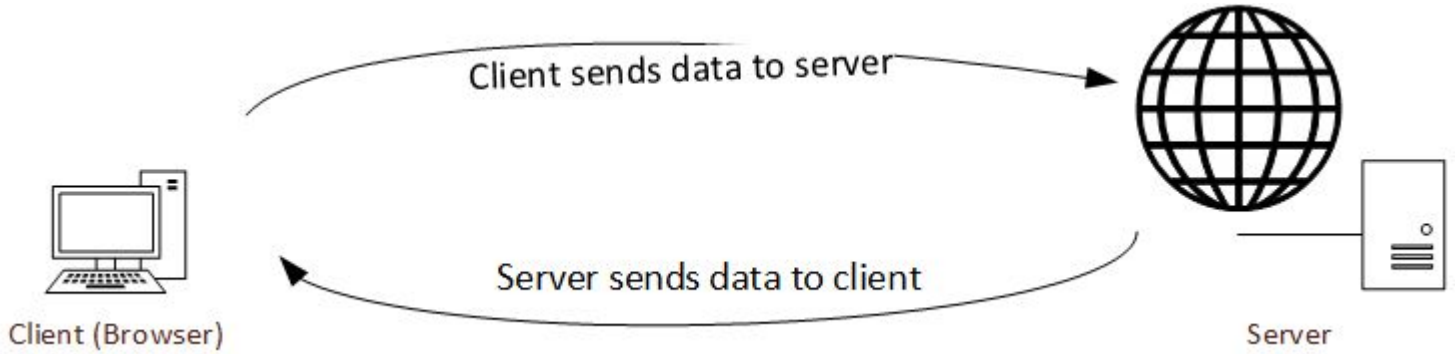
Apa yang terjadi dengan data userid/password yang dikirim ke server?

Mungkinkah terjadi “penyerobotan” data (sniffing attack) di tengah perjalanan?

Mengamankan Transmisi Data

Penggunaan SSL/TLS untuk komunikasi antara client dengan server menggunakan port 443 dan akan ditandai dengan penggunaan protokol HTTPS pada browser

Cara Kerja Secara Umum



Secara umum, komunikasi yang terjadi adalah didahului dari client di mana client akan mengirim data ke server dan server akan meresponnya dengan mengirim data yang diminta oleh client

Cara Kerja

1. Akan ada 1 tahap sebelum transmisi data benar-benar terjadi yang dinamakan SSL Handshake
   Cara kerja:
   a. Client mengirim request ke server
   b. server mengirimkan copy certificate dari SSL/TLS dan Public Key
   c. Browser akan menciptakan random session Key lalu mengenkrip Session Key itu menggunakan Public Key milik server dan mengirimkannya ke server
   d. Server mendekrip session key yang terenkrip itu menggunakan Private Key milik server sendiri

Cara Kerja

2. Selanjutnya, setiap kali client akan mengirimkan data ke Server, data tersebut akan dienkrip menggunakan Session Key.
3. Server yang menerima data dari Client akan mendekrip terlebih dulu data itu menggunakan Session Key yang diterima di tahap Handshake
4. Jika Server hendak memberikan respon yaitu mengirimkan data ke client, data akan dienkrip juga menggunakan Session Key tersebut
5. Client akan mendekrip kiriman data dari Server menggunakan Session Key sebelum diolah dan ditampilkan di browser.

Kesimpulan

1. Penggunaan SSL/TLS membuat transmisi data menjadi lebih aman
2. Session Key bersifat simetris dan hanya berlaku pada sesi itu saja
3. Terdapat tambahan langkah (handshake, enkrip+dekrip data) yang mempengaruhi kecepatan komunikasi

Pertanyaan

Berapa tarif SSL?

Beli di mana?

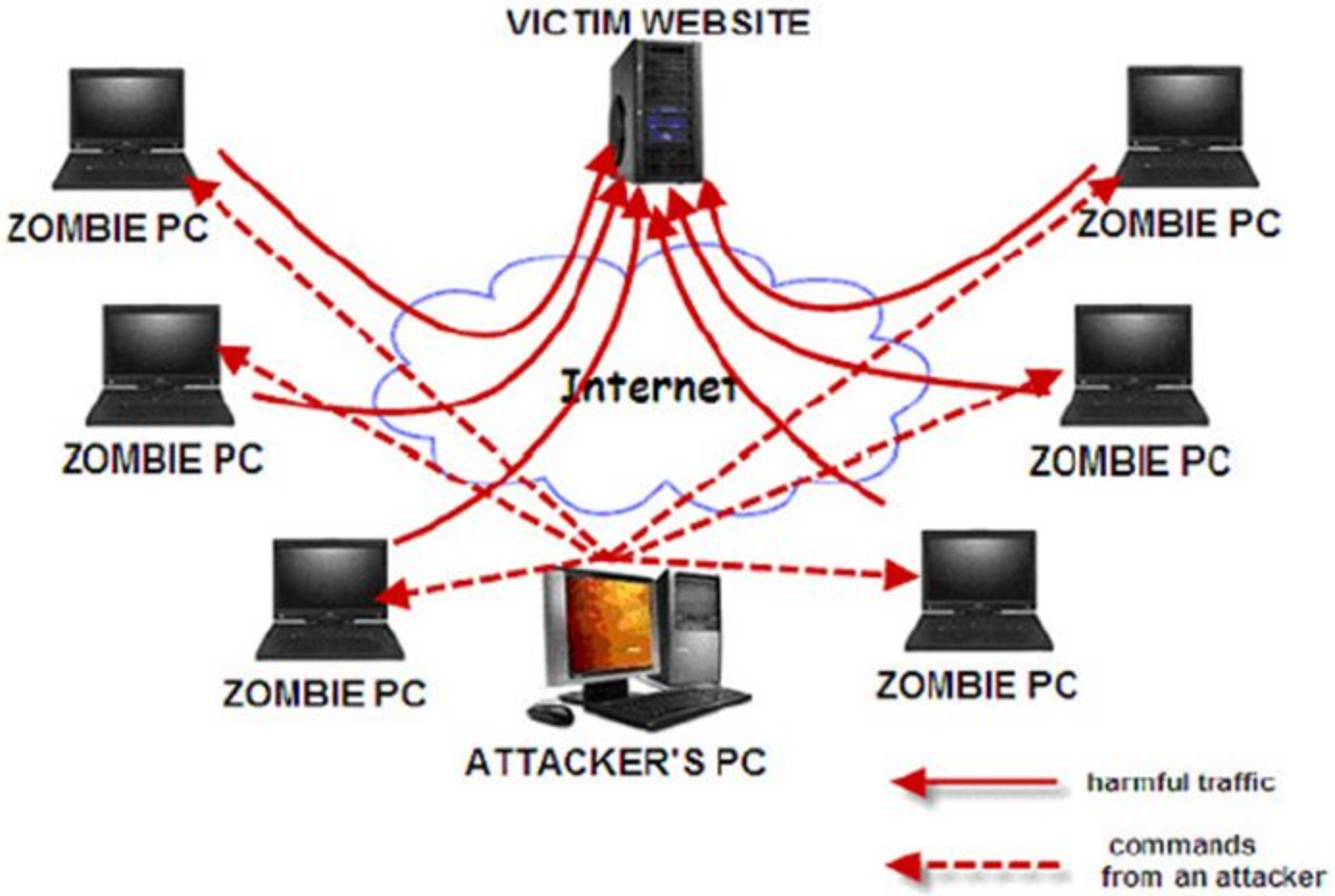
Replay Attack

Replay Attack

- Replay Attack adalah serangan jahat pada aplikasi web, atau pada level yang lebih rendah pada jaringan, di mana data yang dikomunikasikan diulang-ulang.
- Ini dapat dilakukan dengan mencegat data atau mengelabui pengguna atau sistem pengguna agar mengulangi suatu tindakan.
- Tujuan serangan bisa untuk mendapatkan akses ke sistem (misalnya, mengulangi upaya login dari sumber lain), menyebabkan perubahan sistem (misalnya menjalankan perintah stop untuk server virtual melalui API), atau mengisi sistem dengan duplikat atau kesalahan data.

DDoS Attack

- DDoS adalah salah satu Replay Attack yang umum
- Dalam serangan DDoS, lalu lintas masuk yang membanjiri server korban berasal dari berbagai sumber - berpotensi ratusan ribu atau lebih.


VICTIM WEBSITE
ZOMBIE PC
ZOMBIE PC
ZOMBIE PC
ZOMBIE PC
Internet
ZOMBIE PC
ZOMBIE PC
ATTACKER'S PC
harmful traffic
commands
from an attacker

Pencegahan Replay Attack

- Captcha adalah cara yang baik untuk membantu sistem Anda mengidentifikasi pengguna apakah mereka manusia atau Bot
- Cara lain untuk mencegah serangan replay adalah dengan melampirkan timestamp ke pesan yang dikirim antar sistem.
- Sistem penerima dapat mengonfirmasi bahwa timestamp berada dalam rentang yang dapat diterima dan menolak pesan apa pun yang tidak memiliki timestamp atau rentang waktu yang terlalu singkat.

detiknews

Home | Berita | Daerah | Internasional | Fokus | Kolom | Pro Kontra | Infografis | Foto | Vide

Adsmart (NEW) · Most Popular · Hoax or Not · Opini Anda · Suara Pembaca · Blog · Pilkada 2018 (NEW)

detikNews / Berita / Detail Berita

Follow detikcom

Senin 08 Januari 2018, 12:40 WIB

Ada 72 Ribu Pendaftar Paspor Fiktif, Imigrasi Perbaiki Aplikasi

Fajar Pratama - detikNews

3 komentar



Hasil investigasi menunjukan adanya permohonan fiktif yang datanya mencapai 72 ribu lebih. Modus yang dilakukan adalah dengan melakukan pendaftaran online dengan maksud untuk menutup peluang masyarakat lainnya sehingga kuota akan habis.

"Terdapat puluhan oknum masyarakat yang melakukan pendaftaran fiktif, hingga ada beberapa oknum masyarakat yang melakukan pendaftaran fiktif mencapai 4000 lebih dalam sekali pendaftaran oleh satu akun saja. Akibatnya berapapun kuota yang disediakan akan habis diambil oleh oknum masyarakat tetsebut. Selain itu juga ditemukan adanya oknum petugas yang bermain dengan calo," kata Agung.

Latihan

- Buatlah Form sederhana, berupa textbox dan tombol submit
- User boleh mengisikan apa saja dan mengklik tombol submit untuk mengirim data ke server
- Server akan mencatat waktu nya
- Jika user kembali mengklik tombol submit, server akan memeriksa apakah jeda waktunya sudah lebih dari 60 detik
- Jika belum atau kurang dari 60 detik, munculkan error:

“Tunggu x detik lagi”

- Nilai x adalah selisih waktu. Misal user mengklik kali kedua adalah 15 detik setelah yang pertama, maka error yang muncul adalah

“Tunggu 45 detik lagi”

Robot

Robot apa?

Search engine memiliki robot untuk melakukan indexing terhadap semua website yang published, termasuk websitemu

Maka, tentukan bagian mana (file dan folder) yang boleh di-index dan yang tidak boleh diindex

Contoh

Buka:

https://www.google.com/robots.txt

Cari tahu bagaimana cara “mengamankan” foldermu (menjadikan folder mu menjadi tidak terindeks oleh search engine)

“Robot” yang lain ...

Jangan menuliskan alamat email pada halaman web menggunakan plain text!

alternatif:

- menggunakan image
- menggunakan HTML Special Character

Menyembunyikan Daftar Dokumen

Default file

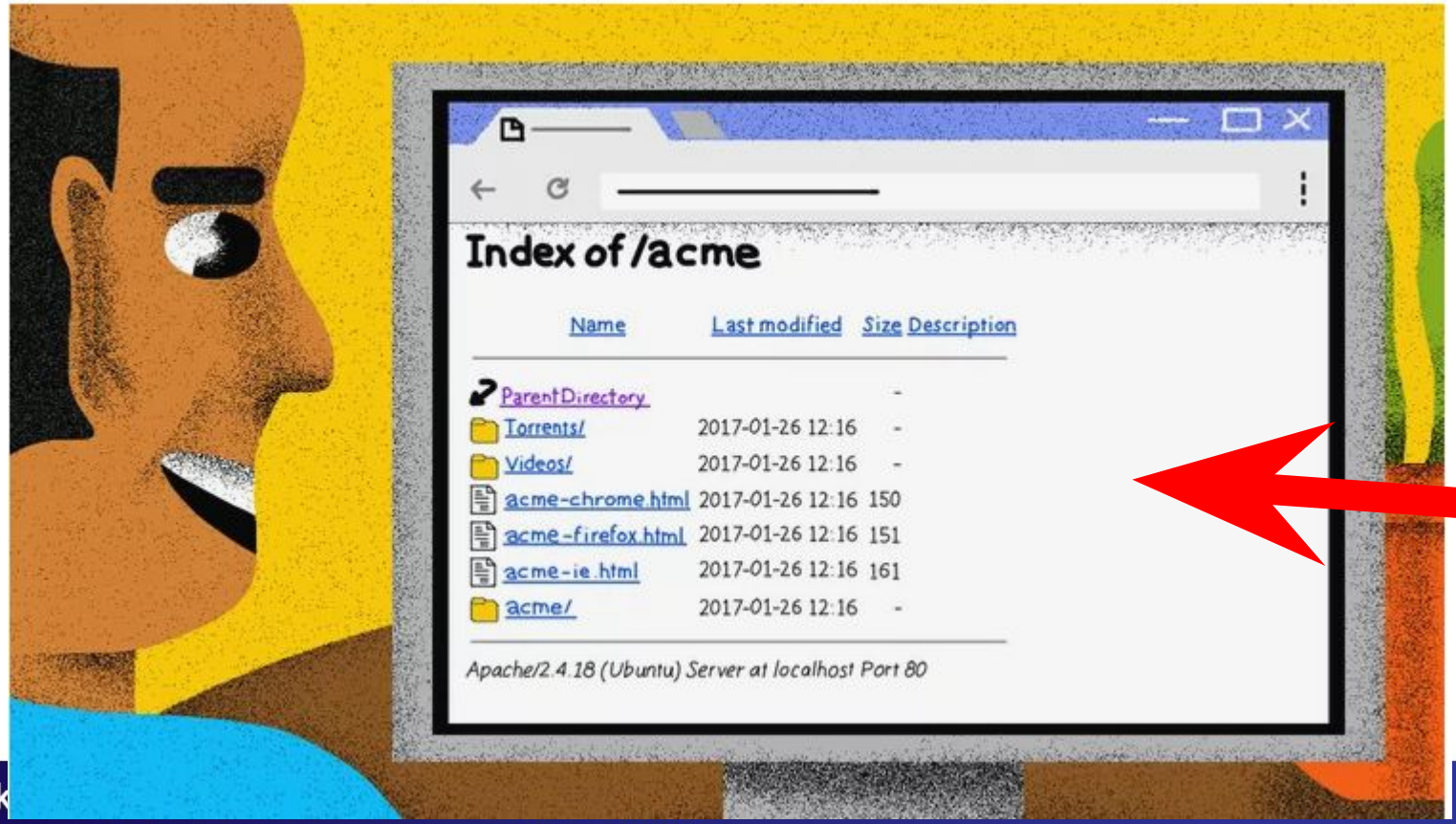
Biasanya, sebuah server memiliki konfirgurasi nama file default yaitu index (index.html, index.php, index.jsp) atau default (default.aspx).

Apa yang akan anda dapatkan jika anda mengetikkan URL berikut: https://www.domainku.com ?

URL di atas tidak menyatakan nama file secara eksplisit.
Maka, server akan menampilkan dokumen default (misal index.html)

Kondisi Tanpa Default file

Apa yang akan anda dapatkan jika anda mengetikkan URL berikut: https://www.domainku.com namun di sana tidak terdapat file default?



Isi directorymu akan terlihat semua

Solusi

Pastikan ada sebuah file default di setiap directory

contoh:

\image\index.html
\css\index.html
\js\index.html
\master\produk\index.php
\master\pegawai\index.php
\index.php

```
<!DOCTYPE html>
<html>
<head>
<title>Forbidden</title>
</head>
<body>
<h1>Forbidden</h1>
</body>
</html>
```

User Profiling

Tabel

1. Buat tabel “profil” : (idprofil, nama)
2. Relasikan dengan tabel user (1-N), di mana 1 user akan memiliki 1 profil dan 1 profil dapat dimiliki banyak user.
   Tabel user akan memiliki FK idprofil
3. Buat tabel “menu” : (idmenu, nama, link)
4. Relasikan dengan tabel “profil” dengan relasi M-N hingga tercipta tabel baru : “menu_profil”

Menu

Apakah anda sudah memisahkan bagian menu di tiap-tiap halaman menjadi file tersendiri (misal: menu.php) dan tinggal di-include di tiap-tiap halaman yang lain?

Jika sudah, berarti kita dapat fokus pada isi file menu.php di mana akan menampilkan sejumlah menu sesuai profil yang dimiliki oleh user yang sedang login

Menu

Aturlah agar halaman menu tertentu hanya boleh dibuka oleh user yang memang memiliki profil tertentu